



Bundesamt
für Sicherheit in der
Informationstechnik

Deutschland
Digital•Sicher•BSI

Technische Richtlinie BSI TR-03192 Wahlunterstützungssoftware: Schnellmeldungen

Version 0.9

Entwurf



Änderungshistorie

Tabelle 1: Änderungshistorie

Version	Datum	Name	Beschreibung
0.1			Initiale Version
0.9			Erste Kommentierungsversion

Danksagung

Die Erstellung dieser Technischen Richtlinie erfolgte unter Mitwirkung zahlreicher fachlicher Beiträge und konstruktiver Workshops.

Unser Dank gilt dem Bundesministerium des Innern (BMI), dem Bundesministerium für Digitales und Staatsmodernisierung (BMDS) sowie der Bundeswahlleitung (BWL) für die vertrauensvolle Zusammenarbeit und die fachliche Unterstützung bei der Entwicklung dieser Richtlinie.

Wir danken insbesondere den Vertreterinnen und Vertretern der Bundesländer, der Kreise und der Kommunen für ihre fachliche Unterstützung, ihre Hinweise aus der Praxis sowie die engagierte Begleitung des Erarbeitungsprozesses der vorliegenden Technischen Richtlinie.

Auch den Herstellern von Wahlunterstützungssoftware danken wir für die Bereitschaft zum konstruktiven Dialog sowie die Einbringung weiterer technischer Expertise im Rahmen der Erarbeitung dieser Technischen Richtlinie.

Durch die gebündelte Fachexpertise konnte gemeinsam ein belastbares und praxisorientiertes Rahmenwerk für den Einsatz und die Prüfung von Wahlunterstützungssoftware geschaffen werden.

Inhalt

1	Einleitung.....	5
1.1	Thematische Einordnung.....	5
1.2	Zielsetzung und Abgrenzung.....	6
1.3	Zielgruppe.....	6
1.4	Regulatorisches und gesetzliches Umfeld.....	7
1.5	Aufbau der Technischen Richtlinie.....	7
1.6	Schlüsselwörter.....	7
2	Technische Rahmenbedingungen.....	9
2.1	Daten und Datenschnittstellen.....	9
3	Angriffsszenarien.....	10
3.1	Annahmen.....	10
3.2	Risiken und Bedrohungen.....	11
4	Sicherheitsanforderungen.....	13
4.1	Allgemeine Anforderungen.....	13
4.2	Architektur.....	14
4.3	Authentisierung, Authentifizierung und Autorisierung.....	14
4.4	Session-Management.....	15
4.5	Webanwendungen.....	16
4.6	Datenintegrität und -vertraulichkeit.....	16
4.7	Eingabevalidierung.....	17
4.8	Dateischnittstellen.....	17
4.9	Protokollierung.....	18
5	Glossar.....	19
6	Abkürzungsverzeichnis.....	20
	Literaturverzeichnis.....	21

1 Einleitung

1.1 Thematische Einordnung

Die *Bundesrepublik Deutschland* ist als *repräsentative Demokratie* organisiert [1]. In ihr spielen Wahlen die zentrale Rolle, um die Staatsgewalt des Volkes auf ihre Repräsentanten in den Parlamenten zu übertragen. Die Parlamentarier werden durch ihre Wahl als Vertreter des Volkes legitimiert und sind darüber hinaus an keine Aufträge und Weisungen gebunden [1]. Bundesweite Wahlen finden regelmäßig für stimmberechtigte Bürgerinnen und Bürger bei Wahlen zum *Deutschen Bundestag* oder bei *Europawahlen* statt.

In Deutschland findet der Wahlvorgang in Wahlkabinen und auf Stimmzetteln statt. Auf Antrag ist auch die Briefwahl möglich. Der Wählende äußert seinen Willen durch Ankreuzen einer Partei und/ oder einer Person. Anschließend werden alle Stimmzettel eines Wahlbezirkes in einer Wahlurne gesammelt. Die Auszählung ist öffentlich und erfolgt nach Schluss der Wahlhandlung durch den Wahlvorstand. Alle Ergebnisse aus den Wahlbezirken werden über die kommunale Gemeindeverwaltung, die Wahlkreisleitung, die Landeswahlleitung bis zur Bundeswahlleitung übermittelt und ausgewertet. Die Meldung der Ergebnisse erfolgt zunächst als Schnellmeldung noch am Wahlabend und stellt das vorläufige amtliche Wahlergebnis dar. Das für die Sitzverteilung im Parlament maßgebliche amtliche Endergebnis wird durch die Wahlorgane im Nachgang festgestellt und wird verkündet, wenn alle Einzelergebnisse erneut überprüft und von den übergeordneten Stellen freigegeben wurden. [2]

Wenngleich beim Wahlvorgang keine EDV-gestützten Technologien zum Einsatz kommen, so wird in aller Regel bei den Vorbereitungen der Wahl und im Nachgang Informationstechnik (IT) verwendet. Dass während der eigentlichen Wahl keine Wahlmaschinen eingesetzt werden, begründet sich aus dem Urteil des Bundesverfassungsgerichts zum Einsatz von rechnergesteuerten Wahlgeräten [3], das hohe Anforderungen insbesondere im Hinblick auf die Öffentlichkeit der Auszählung stellt.

In der Vorbereitung einer bundesweiten Wahl müssen prozessuale und organisatorische Aufgaben betrachtet werden. Dabei kommen in der Regel IT-gestützte Verfahren zum Einsatz. Zu den Aufgaben gehören u. a.:

- Zuschnitt von Wahlkreisen und Wahlbezirken
- Registrierung von Parteien und Kandidaten
- Wahlvorstand und Wahlhelfer bestellen
- Wählerverzeichnis erstellen und Wahlscheine ausstellen
- Stimmzettel drucken

Nach der Wahl, wenn alle Stimmen abgegeben sind und die Wahllokale geschlossen wurden, fallen weitere Aufgaben an:

- Öffnung der Wahlurne und öffentliche Auszählung aller Stimmen
- Übermittlung des Auszählungsergebnisses an die für den Wahlbezirk zuständige Gemeinde
- Schnellmeldung an die Kreiswahlleitung, die Landeswahlleitung und Bundeswahlleitung
- Veröffentlichung der Ergebnisse und Feststellung des vorläufigen amtlichen Wahlergebnisses
- Nach erneuter Prüfung der Wahl, Feststellung und Bekanntgabe des amtlichen Endergebnisses

In vielen der genannten Aufgaben kommt *Wahlunterstützungssoftware* (WUS) zum Einsatz. Aus Sicht der IT-Sicherheit sind Bereiche, in denen sensible Daten ausgetauscht werden und Systeme, die in verteilte Netze (z. B. Internet, Verwaltungsnetze) eingebunden sind, von besonderem Interesse.

1.2 Zielsetzung und Abgrenzung

Die sichere Durchführung parlamentarischer Wahlen ist von hoher Bedeutung und Grundbedingung für das Vertrauen der Bevölkerung in die Wahlorganisation und die Akzeptanz des Wahlergebnisses. Der Schutz vor illegitimer Einflussnahme ist hierbei ein wichtiger Faktor, um sichere Wahlen als ein Kernelement der Demokratie zu gewährleisten. Ziel der vorliegenden Technischen Richtlinie ist es daher, einheitliche und verbindliche Sicherheitsvorgaben für Wahlunterstützungssoftware mit Schnellmeldungen bei bundesweiten parlamentarischen Wahlen zu formulieren.

Die vorliegende Technische Richtlinie befasst sich mit den Schnellmeldungen bei bundesweiten Wahlen. Sie dienen dazu, die vorläufigen Wahlergebnisse noch am Wahlabend zu aggregieren, um das vorläufig ermittelte amtliche Wahlergebnis für Bürgerinnen und Bürger transparent bekanntgeben zu können. Im Fokus der Technischen Richtlinie steht die IT-gestützte Übermittlung dieser Schnellmeldungen, die über Wahlunterstützungssoftware aus den Wahlkreisen über die föderalen Ebenen hinweg bis zur Bundeswahlleitung geprüft und weitergeleitet werden. Software (z. B. Office Anwendungen), welche nicht spezifisch für diesen Zweck entwickelt wurde sowie Meldungen, die fernmündlich oder per Telefax erfolgen, sind nicht Gegenstand der vorliegenden Technischen Richtlinie.

Für die vorliegende Technische Richtlinie wird die bei den Schnellmeldungen zum Einsatz kommende Wahlunterstützungssoftware nach dem Stand der Technik, im Hinblick auf die IT-Sicherheitsziele Verfügbarkeit, Integrität und Vertraulichkeit betrachtet. Darauf abzielend werden Sicherheitsanforderungen formuliert. Im Mittelpunkt stehen dabei Webanwendungen bzw. Webservices mit ihren verschiedenen Schnittstellen, welche für die Übermittlung der vorläufigen Wahlergebnisse zum Einsatz kommen.

Durch die aufgestellten Sicherheitsanforderungen der vorliegenden Technischen Richtlinie werden die Grundlagen für eine Produktzertifizierung geschaffen. Die zugehörige Prüfspezifikation wird in einem separaten Anhang veröffentlicht. Anzumerken ist, dass eine Produktzertifizierung wesensbedingt keine organisatorischen oder infrastrukturellen Maßnahmen abdecken kann. Eine Produktzertifizierung richtet sich ausschließlich an die zur Verfügung gestellte Software und die in ihrem Einfluss liegenden Verantwortlichkeiten.

Parallel zur Technischen Richtlinie werden praxisorientierte Lösungsansätze und organisatorische Maßnahmen mit Vertreterinnen und Vertretern aus Bund, Ländern und Kommunen entwickelt. Dabei stehen IT-Grundschutzprofile und skalierbare Handreichungen für den Einstieg und die Umsetzung des IT-Grundschutzes im Fokus. Hervorzuheben ist dabei das *IT-Grundschutz-Profil Schnellmeldungen – Absicherung der Schnellmeldungen bei bundesweiten parlamentarischen Wahlen*.

1.3 Zielgruppe

Die vorliegende Technische Richtlinie richtet sich primär an Hersteller und Anbieter von Wahlunterstützungssoftware, die IT-Lösungen für die Aggregation und Weitergabe der Schnellmeldungen entwickeln und vertreiben. Darüber hinaus sind die abgeleiteten Sicherheitsanforderungen für weitere Zielgruppen von Interesse:

- Hersteller, die Wahlunterstützungssoftware zum Einsatz bei parlamentarischen Wahlen entwickeln
- Anbieter einer Wahlunterstützungssoftware
- Verantwortliche für die IT-Sicherheit in Institutionen oder Verwaltungen, die Wahlunterstützungssoftware beschaffen, betreiben oder nutzen
- IT-Dienstleister, die mit der Implementierung, dem Betrieb und der Wartung von Wahlunterstützungssoftware betraut sind
- Organisationen, die Wahlunterstützungssoftware zertifizieren möchten und die Einhaltung der IT-Sicherheitsanforderungen prüfen bzw. sicherstellen müssen

Des Weiteren bietet die vorliegende Technische Richtlinie Orientierung für alle, die Wahlunterstützungssoftware im Rahmen gesetzlicher Vorgaben und gemäß anerkannter IT-Sicherheitsstandards einsetzen möchten.

1.4 Regulatorisches und gesetzliches Umfeld

Parlamentarische Wahlen unterliegen besonderen gesetzlichen Rahmenbedingungen, die über bundes- und landesrechtliche Wahlgesetze und -ordnungen geregelt sind.

Die gesetzlichen Regelungen zu Wahlverfahren in der Bundesrepublik Deutschland finden sich im Grundgesetz (GG) [1] im Artikel § 38, für die Bundestagswahl im Bundeswahlgesetz (BWG) [4] bzw. bei Wahlen zum Europäischen Parlament im Europawahlgesetz (EuWG) [5]. Ergänzt werden diese gesetzlichen Regelungen für bundesweite parlamentarische Wahlen durch die Bundeswahlordnung (BWO) [2] bzw. die Europawahlordnung (EuWO) [6].

In der jeweiligen Wahlordnung werden die Details zur Durchführung der Wahlen konkretisiert und die Organisation und Abläufe der Wahlhandlung, einschließlich der Ergebnisermittlung beschrieben. Hierunter fallen auch Vorgaben zum Vorgehen bei der Ermittlung und Übermittlung der vorläufigen Wahlergebnisse am Wahltag (Schnellmeldungen).

1.5 Aufbau der Technischen Richtlinie

Die Einleitung der Technischen Richtlinie gibt eine Einordnung zum Kontext, zur fachlichen Zielsetzung, und den adressierten Zielgruppen der vorliegenden Richtlinie. Die Rahmenbedingungen erläutern die technischen Grundlagen für den Einsatz von Wahlunterstützungssoftware und gehen dabei auf mögliche Bedrohungen und Angriffsszenarien ein; weitere Risiken werden benannt.

Die Sicherheitsanforderungen an Wahlunterstützungssoftware und deren Einsatzumgebung umfassen die Bereiche:

- Allgemeine Anforderungen
- Architektur
- Authentisierung, Authentifizierung und Autorisierung
- Session-Management
- Webanwendungen
- Datenintegrität und -vertraulichkeit
- Eingabevalidierung
- Dateischnittstellen
- Protokollierung

Im Dokument verwendete Begriffe und Abkürzungen werden am Ende des Dokumentes gelistet. Das Literaturverzeichnis enthält die referenzierten Quellen und Dokumente.

1.6 Schlüsselwörter

In den Anforderungen werden die in Versalien geschriebenen Modalverben „SOLLTE“ und „MUSS“ in ihren jeweiligen Formen sowie den zugehörigen Verneinungen genutzt, um zu verdeutlichen, wie die jeweiligen Anforderungen zu interpretieren sind. Die hier genutzte Definition basiert auf dem BSI IT-Grundschutz [7] und RFC2119 [8].

MUSS/ DARF NUR

Dieser Ausdruck bedeutet, dass es sich um eine Anforderung handelt, die unbedingt erfüllt werden muss (uneingeschränkte Anforderung).

DARF NICHT/ DARF KEIN	Dieser Ausdruck bedeutet, dass etwas in keinem Fall getan werden darf (uneingeschränktes Verbot).
SOLLTE	Dieser Ausdruck bedeutet, dass eine Anforderung normalerweise erfüllt werden muss, es aber Gründe geben kann, dies doch nicht zu tun. Dies muss aber sorgfältig abgewogen und stichhaltig begründet werden.
SOLLTE NICHT/ SOLLTE KEIN	Dieser Ausdruck bedeutet, dass etwas normalerweise nicht getan werden sollte, es aber Gründe gibt, dies doch zu tun. Dies muss aber sorgfältig abgewogen und stichhaltig begründet werden.
KANN	Dieser Ausdruck bedeutet, dass eine bestimmte Umsetzung gewählt werden kann. Diese muss allerdings angezeigt werden.

Die Technische Richtlinie repräsentiert den Stand der Technik und wird fortlaufend aktualisiert.

2 Technische Rahmenbedingungen

Bei der Übermittlung der Schnellmeldungen aus den bundesweit verteilten Wahlbezirken kommen überwiegend Webanwendungen zum Einsatz. Diese werden in der Regel von den Landeswahlleitungen oder der Bundeswahlleitung betrieben, bzw. die Aufgabe wird an Dienstleister übertragen. Im Folgenden soll ein kurzer Einblick in die Funktionsweise einer Webanwendung gegeben werden.

Eine Webanwendung ist ein verteiltes Softwaresystem, das über standardisierte Webprotokolle bereitgestellt wird und dessen Nutzung im Webbrowser erfolgt. Dadurch entfällt die Installation von zusätzlicher Software auf der Seite der Benutzer. Die Architektur folgt dem *Client-Server-Modell*, bei dem *Browser* und *Webserver* klar definierte Verantwortlichkeiten übernehmen. Der Browser stellt hauptsächlich die Präsentationsschicht (*Frontend*) bereit: Er rendert *HTML*-Strukturen, interpretiert *CSS*-Regeln und führt clientseitig *JavaScript*-Code aus, um Benutzerinteraktionen, Formularvalidierung, dynamische *UI*-Anpassungen und asynchrone Datenabfragen zu ermöglichen. Der Webserver bildet eine zentrale Komponente des *Backends* der Anwendung. Er verarbeitet eingehende *HTTP Requests*, führt die Geschäftslogik aus, kommuniziert mit Datenbanken oder externen Diensten und erzeugt dynamische Inhalte, die dem Browser als *HTML*, *JSON* oder andere Datenformate bereitgestellt werden. Diese Aufgabenteilung schafft eine Trennung zwischen Darstellung, Logik und Datenhaltung und ermöglicht skalierbare, modular strukturierte Websysteme.

Für die Implementierung kommen unterschiedliche Technologien zum Einsatz. Auf der Clientseite dominiert *JavaScript* als universelle Laufzeitsprache in allen modernen Browsern, ergänzt durch *HTML* und *CSS* zur Strukturierung und Gestaltung der Benutzeroberfläche. Serverseitig werden verbreitete Programmiersprachen wie *Java*, *Python*, *PHP*, *Rust* oder *Go* eingesetzt. Frameworks wie *Spring*, *Django*, *Laravel* oder *Express* kapseln wiederkehrende Aufgaben, wie Routing, Datenbankzugriffe oder Authentifizierung und unterstützen eine standardisierte, wartbare Entwicklung.

Da *HTTP* ein zustandsloses Protokoll ist, benötigen Webanwendungen Mechanismen zur Aufrechterhaltung von Benutzerzuständen. Dies erfolgt über *stateful Sessions*. Beim ersten Zugriff erzeugt der Server eine eindeutige *Session-ID* und speichert zugehörige Zustandsdaten, wie bspw. Authentifizierungsinformationen oder Benutzereinstellungen, in einer serverseitigen Datenstruktur ab. Die *Session-ID* wird dem Browser üblicherweise über ein *Cookie* bereitgestellt. Bei jedem weiteren Request übermittelt der Browser dieses *Cookie* automatisch, sodass der Server die *Session* eindeutig zuordnen und die zugehörigen kontextbezogenen Daten abrufen kann.

Für den sicheren Betrieb einer Webanwendung sind IT-Schutzmechanismen an verschiedenen Stellen essenziell. Zentrale Maßnahmen umfassen die Transportverschlüsselung mittels *TLS*, um Daten vor Manipulation und Ausspähen zu schützen sowie Authentifizierung und Autorisierung zur Kontrolle des Zugriffs geschützter Ressourcen. Verbreitete Angriffsszenarien im Zusammenhang mit Webapplikationen finden sich bspw. im OWASP-Katalog [9].

2.1 Daten und Datenschnittstellen

Zurzeit werden in den betrachteten Softwarelösungen keine automatischen Datenschnittstellen (API) zur Übertragung von Ergebnismeldungen eingesetzt. Anforderungen an die *machine-to-machine* (M2M) Kommunikation zur Übermittlung von Ergebnismeldungen sind daher nicht Gegenstand dieser Technischen Richtlinie. Hiervon unberührt bleiben Anforderungen an interne oder sonstige Kommunikationsbeziehungen zwischen Komponenten im Backend der Wahlunterstützungssoftware.

3 Angriffsszenarien

3.1 Annahmen

Im Folgenden werden Annahmen über das Betriebsumfeld formuliert. Sie umfassen zentrale Sicherheitsaspekte und Prozesse, die bei der Übertragung von Schnellmeldungen essentiell sind, aber nicht im Rahmen einer Produktzertifizierung geprüft werden. Die vorgestellten Annahmen sind nicht abschließend und sollen der Sensibilisierung der Betriebsverantwortlichen dienen.

Tabelle 2: Annahmen über sicherheitsrelevante Maßnahmen im Informationsverbund, die über den Rahmen der vorliegenden Technischen Richtlinie hinaus gehen.

Gegenstand	Annahme
Webserver	Der physische Webserver befindet sich in einer geschützten Umgebung. Durch organisatorische und technische Maßnahmen ist sichergestellt, dass Angreifer sich keinen physischen Zugriff verschaffen können. Administrative Maßnahmen sind nicht über öffentliche Netze möglich. Für die Webserverapplikation und seine Erweiterungen werden regelmäßig Sicherheitsupdates zur Verfügung gestellt und eingespielt. Die Konfiguration wird gemäß dem Einsatzzweck gehärtet. Es wird nur Software aus vertrauenswürdigen Quellen verwendet. Wird der Webserver von mehreren Mandanten genutzt, so ist sichergestellt, dass Daten und Ressourcen nur durch berechtigte Mandanten eingesehen und verändert werden können. Die gemeinsame Nutzung von IT-Infrastruktur ist auf ein Minimum reduziert und durch den Einsatz von <i>Virtual Machines</i> (VM) oder durch Containerisierung weitgehend separiert.
Hintergrundsystem (Backend)	Es wird nur Software verwendet, die vom Hersteller der Wahlunterstützungssoftware für den Anwendungszweck dafür freigegeben wurde. Die Installationsdateien stammen aus vertrauenswürdigen Quellen und sind integritätsgeschützt.
Webzugang/ Netze	Der Webserver, der die Wahlunterstützungssoftware bereitstellt, ist nicht unmittelbar über öffentliche Netze erreichbar bzw. der Zugriff ist auf das notwendige Maß beschränkt und durch technische und organisatorische Sicherheitsmaßnahmen geeignet abgesichert. Dies umfasst bspw. restriktive Firewall-Einstellungen, <i>IP-Adress-Whitelisting</i> , VPN-Verbindungen. Bei netzwerkseitig erreichbaren Diensten wird die Skalierbarkeit der Anfragen berücksichtigt und es werden Maßnahmen zu <i>Denial-of-Service</i> -Angriffen umgesetzt.
Client (Endgerät des Benutzers)	Das Betriebssystem wird aktuell gehalten und durch regelmäßige Sicherheitsupdates geschützt. Sicherheitsfunktionen des Betriebssystems werden nicht umgangen. Es findet eine regelmäßige Überprüfung nach Schadsoftware statt. Es wird nur Software aus vertrauenswürdigen Quellen verwendet.
Browser	Der durch den Benutzer verwendete Browser ist aktuell und entspricht dem Stand der Technik. Für ihn werden regelmäßig Sicherheitsupdates zur Verfügung gestellt und eingespielt. Er implementiert das TLS-Protokoll gemäß den Empfehlungen des BSI.
Betriebsverantwortliche Stelle	Der Betreiber entwickelt ein Rollenkonzept für den Einsatz und Umgang mit der Software. Er weist Benutzer entsprechend ihren Rollen in die Software ein und informiert über sicherheitsrelevante Vorgaben.

<i>Gegenstand</i>	<i>Annahme</i>
Benutzer	Die Zugangsdaten für die Webanwendung gelangen auf sicherem und geschütztem Weg zum Benutzer. Bei der Übermittlung der Schnellmeldung prüft er in der Adresszeile des Browsers, ob er mit der korrekten Webadresse verbunden ist und ob die Verbindung über TLS verschlüsselt und integritätsgeschützt erfolgt (z. B. über das <i>https</i> Protokoll). Er verwendet mindestens die standardmäßigen Sicherheitseinstellungen des genutzten Webrowsers.

3.2 Risiken und Bedrohungen

Der Einsatz von Wahlunterstützungssoftware im Rahmen der Schnellmeldungen bundesweiter Wahlen ist mit verschiedenen technischen und organisatorischen Risiken verbunden. Diese Risiken können die Verfügbarkeit, Integrität, Authentizität und Nachvollziehbarkeit der verarbeiteten Wahldaten beeinträchtigen und somit Auswirkungen auf die ordnungsgemäße Durchführung von Schnellmeldungen haben. Die nachfolgend aufgeführten Risiken stellen eine beispielhafte Übersicht relevanter technischer und organisatorischer Gefährdungen dar und sind überwiegend aus [7] und [9] zusammengestellt. Insbesondere die technischen Risiken wurden in den Sicherheitsanforderungen adressiert, die organisatorischen Maßnahmen sind Hinweise an die fachlich verantwortlichen Stellen.

Technische Risiken

- Fehlerhafte Zugriffskontrolle sowie Fehler bei Authentifizierung und Identitätsprüfung
- Sicherheitsfehlkonfigurationen
- Unsicheres Softwaredesign
- Schwachstellen in der Software-Lieferkette
- Kryptografische Schwachstellen
- Injection-Schwachstellen
- Fehler bei der Software- oder Datenintegrität
- Unzureichende Patch- und Sicherheitsupdates
- Unzureichende Sicherheitsprotokollierung und Alarmierung
- Fehlerhafter Umgang mit Ausnahme- und Fehlerzuständen

Organisatorische Risiken

- Unklare Rollen und Verantwortlichkeiten sowie unzureichende Berechtigungen und Freigaben
- Unzureichende physische Zugangskontrollen
- Unzureichende Kontrolle externer Dienstleister
- Unzureichende Schulung und Sensibilisierung der beteiligten Personen
- Fehlerhafte manuelle Datenerfassung oder Datenübertragung
- Unzureichende Überprüfung von Schnellmeldungen
- Unsichere Kommunikations- und Meldewege
- Unzureichendes Änderungsmanagement (Change-Management)
- Unzureichende Notfall-, Wiederanlauf-, Incident- und Krisenmanagementprozesse
- Unzureichende Abstimmung zwischen Wahlbehörden und IT-Dienstleistern

- Fehlende oder unvollständige Dokumentation einschließlich der Protokollierung organisatorischer Prozessschritte
- Zeitdruck und hohe Arbeitsbelastung am Wahltag sowie fehlende Vertretungsregelungen

Die aus den Risiken abgeleiteten Bedrohungen dienen als Leitlinien bei der Gestaltung der IT-Sicherheitsanforderungen in Kapitel 4.

Tabelle 3: Bedrohungsszenarien beim Schnellmeldeprozess

Bedrohung	Schutzziel	Szenario
Manipulation von Eingabedaten	Integrität	Falsche Zahlen zur Schnellmeldung werden bereits im Wahllokal oder bei der ersten elektronischen Erfassung im Wahlsystem eingetippt, z. B. Social Engineering gegenüber Wahlhelfenden, Schadsoftware auf Erfassungsrechnern, USB-Sticks.
Angriffe auf Übertragungsweg	Vertraulichkeit/ Integrität	Gezielte Störung von Datenleitungen, Ausnutzen unzureichend gesicherter Kanäle (z. B. unsichere VPN-Konfigurationen, veraltete Protokolle, <i>Man-in-the-middle</i> -Angriffe).
Kompromittierung der Aggregation von Wahldaten	Integrität	Angriff auf Dokumentenablagen, Datenbanken oder Software zur Ergebnisaggregation von Schnellmeldungen. Insider-Manipulation einzelner Datenfelder, gezielte Fehler in Berechnungs- und Summenlogik. Manipulation von Exportschnittstellen oder E-Mail-Postfächern.
Verfügbarkeitsangriffe	Verfügbarkeit	Überlastung von Servern der Wahlleitungen, Schnittstellen zu Medien oder öffentlichen Ergebniswebseiten.
Kompromittierung von Zugängen und Identitäten	Integrität/ Vertraulichkeit	Übernahme von Benutzerkonten in Kommunen oder bei IT-Dienstleistern (<i>Phishing</i> , <i>Credential Stuffing</i> , <i>Malware</i>).
Manipulation der Hintergrundsysteme	Integrität	Durch externe oder interne Akteure werden Daten oder Logdateien verändert um Ergebnisse zu beeinflussen oder Handlungen zu verschleiern.
Erweiterte Angriffsfläche durch ungesicherte/ undokumentierte Schnittstellen	Integrität	Die WUS verfügt über Hintertüren, bspw. undokumentierte Schnittstellen, über die Sicherheitsmechanismen umgangen und Daten verändert werden können.

4 Sicherheitsanforderungen

Dieses Kapitel führt die IT-Sicherheitsanforderungen auf, die im Rahmen der Schnellmeldungen für Wahlunterstützungssoftware relevant sind. Zunächst werden allgemeine Anforderungen für die Entwicklung von Wahlunterstützungssoftware formuliert. Anschließend werden Technologien im Umfeld von Webanwendungen technologieneutral betrachtet. Jeder Schwerpunkt wird in einem separaten Unterkapitel zusammengefasst. Als Grundlage dient das IT-Grundsatzkompodium [7] und weitere Technische Richtlinien des BSI, es werden allerdings auch Schwachstellen aus Katalogen wie OWASP [9] oder Bug-Bounty Programmen mit einbezogen.

Die Anforderungen der Technischen Richtlinie BSI TR-03185 „Sicherer Software-Lebenszyklus“ [10] werden durch diese Technische Richtlinie nicht verbindlich vorausgesetzt. Herstellern wird jedoch empfohlen, die in der TR-03185 beschriebenen Maßnahmen bereits während der Softwareentwicklung zu berücksichtigen und deren Umsetzung zu dokumentieren. Eine frühzeitige Orientierung an den Anforderungen der TR-03185 kann Nachweise zur Umsetzung sicherheitsrelevanter Softwareentwicklungsprozesse erleichtern und eine spätere Bewertung der Wahlunterstützungssoftware unterstützen.

4.1 Allgemeine Anforderungen

Allgemeine Anforderungen richten sich vorwiegend an die Software während der Entwicklungsphase. Sie legen Grundzüge für eine prüf- und wartbare Software fest.

- A.01.01** *Security-by-Design* und *Security by Default* MÜSSEN ein fester Bestandteil des Softwareentwicklungs- und Lebenszyklus für die gesamte Webanwendung sein.
- A.01.02** Ein geeignetes Vorgehensmodell zur Softwareentwicklung, -erweiterung und -änderung MUSS festgelegt und dokumentiert werden. Bei einer Softwareentwicklung SOLLTE ein geeignetes Steuerungs- bzw. Projektmanagementmodell auf Basis des ausgewählten Vorgehensmodells verwendet werden.
- A.01.03** Es MUSS eine Richtlinie für die Softwareentwicklung erstellt und aktuell gehalten werden. Die Richtlinie sollte neben Namenskonventionen auch Vorgaben zu Elementen beinhalten, die verwendet bzw. nicht verwendet werden dürfen. Die Richtlinie MUSS für die Entwickelnden verbindlich sein. Die Einhaltung der Richtlinie MUSS im Entwicklungsprozess überprüfbar sein.
- A.01.04** Der Quellcode des Entwicklungsprojekts MUSS über eine geeignete Versionsverwaltung verwaltet werden. Der Hersteller MUSS den Zugriff auf die Versionsverwaltung regeln und festlegen, wann Änderungen am Quellcode durch die Entwickelnden als eigene Version in der Versionsverwaltung gespeichert werden sollen. Es MUSS sichergestellt sein, dass durch die Versionsverwaltung alle Änderungen am Quellcode nachvollzogen und rückgängig gemacht werden können.
- A.01.05** Die Versionierungen einer Auslieferungsssoftware MÜSSEN verständlich und nachvollziehbar gewählt werden. Release Notes MÜSSEN erstellt werden. Insbesondere SOLLTEN Informationen zu sicherheitskritischen Updates und Supportdauer einer Version enthalten sein.
- A.01.06** Sofern Installations-, Update- oder Patch-Dateien vom Hersteller über Server zur Verfügung gestellt werden, MÜSSEN sie mit digitalen Signaturen bereitgestellt werden, um Authentizität und Integrität der Software sicherzustellen. Für digitale Signaturen DÜRFEN NUR kryptografisch sichere Signaturverfahren gemäß BSI TR-03116-4 „*Kryptographische Vorgaben für Projekte der Bundesregierung Teil 4*“ in der aktuellen Version verwendet werden. [11]
- A.01.07** Wird die Wahlunterstützungssoftware in einem Containerumfeld betrieben und über eine CI/CD Pipeline ausgerollt, so MUSS die Pipeline den Anforderungen gemäß SLSA Level 2 [12] genügen. In diesem Fall MÜSSEN Updates durch automatisierte Tests, Security-Scans, versionierte Images, getrennte Entwicklungsumgebungen und kontrollierte Deployments mit Rollback-Fähigkeit ausgeführt werden.

- A.01.08** Der Hersteller KANN die Möglichkeit zu *reproduzierbaren Builds* für *Software-Artifacts* unterstützen.

4.2 Architektur

Dieser Abschnitt legt Anforderungen an die Softwarearchitektur und Dokumentation der einzelnen Komponenten fest. Außerdem werden Sicherheitsvorgaben zu Interaktionen zwischen Komponenten im Hintergrundsystem gemacht, die nicht zur unmittelbaren Kernanwendung der Wahlunterstützungssoftware gehören.

- A.02.01** Die Entwickelnden MÜSSEN die Softwarearchitektur der Webanwendung mit allen Bestandteilen und Abhängigkeiten zu Schnellmeldungen dokumentieren. In der Dokumentation SOLLTEN alle für den Betrieb notwendigen Komponenten gekennzeichnet werden, die nicht Bestandteil der Webanwendung sind. In der Dokumentation SOLLTE beschrieben sein, welche Komponenten welche Sicherheitsmechanismen umsetzen, wie die Webanwendung in eine bestehende Infrastruktur integriert wird und welche kryptografischen Funktionen und Verfahren eingesetzt werden.
- A.02.02** Der Zugriff auf Hintergrundsysteme, auf die Funktionen und Daten ausgelagert werden (z. B. Datenbanken, Protokollserver), MUSS ausschließlich über definierte Schnittstellen und von definierten IT-Systemen aus möglich sein. Die Anwendung MUSS dafür eine geeignete Authentifizierung verwenden.
- A.02.03** Der Hersteller MUSS eine umfassende Liste aller Abhängigkeiten externer Software, Bibliotheken und Frameworks führen und dabei eine *Software Bill-of-Materials* (SBOM) gemäß den Anforderungen der BSI TR-03183-2 "*Cyber-Resilienz-Anforderungen an Hersteller und Produkte*" [13] erstellen und pflegen.
- A.02.04** Sicherheitsupdates MÜSSEN zeitnah bewertet, integriert und den Benutzern bereitgestellt werden. Der Softwarehersteller MUSS ein dokumentiertes Sicherheitskonzept und Schwachstellenmanagement etablieren, die die Behandlung von Schwachstellen in Abhängigkeit ihrer Kritikalität regeln. Die zulässigen Übergangsfristen MÜSSEN definiert und nachvollziehbar begründet werden. Nach Ablauf der festgelegten Übergangsfrist DÜRFEN betroffene Komponenten NICHT mehr produktiv betrieben werden.
- A.02.05** Es SOLLTEN Werkzeuge der statischen Codeanalyse verwendet und auftretende Schwachstellen bewertet werden.
- A.02.06** Wird im Rahmen des Entwicklungs- und Implementierungsprozesses auf externe Bibliotheken zurückgegriffen, MÜSSEN diese aus vertrauenswürdigen Quellen bezogen werden. Bevor externe Bibliotheken verwendet werden, MUSS deren Integrität durch Überprüfung der kryptographischen Signatur sichergestellt sein.
- A.02.07** Alle Optionen zur Unterstützung der Entwicklung (z. B. Entwickler-URLs, Testmethoden, Überreste von Debug-Mechanismen, entsprechende Compilerswitches etc.) MÜSSEN in der Produktivversion vollständig entfernt sein.
- A.02.08** Die Anwendung SOLLTE ein Konzept vorhalten, welches den Austausch der Verschlüsselungsverfahren für *Data-in-Transit* und *Data-at-Rest* ermöglicht (Kryptoagilität).

4.3 Authentisierung, Authentifizierung und Autorisierung

Die Anforderungen dieses Abschnitts beziehen sich nicht nur auf die Authentisierung, Authentifizierung und Autorisierung der Benutzer der Webanwendung, sondern auch auf Zugänge für Fach- und Systemadministratoren.

- A.03.01** Die Webanwendung MUSS über ein *Rechte- und Rollenmanagement* (IAM) verfügen, um den Zugang zu schützenswerten Ressourcen auf berechtigte Benutzer einschränken und durchsetzen zu können. Dabei MUSS das IAM es ermöglichen verschiedene Administratorrollen (z. B. Systemadministrator, Fachadministrator) festzulegen, sowie den verschiedenen Benutzerkonten unterschiedliche Zugriffsrechte (z. B. lesen, schreiben, erstellen, löschen) entsprechend ihrem Verantwortungsbereich zu ermöglichen.
- A.03.02** Für alle Benutzerkonten MUSS ein Anmeldevorgang implementiert werden bevor auf Dienste und Ressourcen der Anwendung zurückgegriffen werden kann. Die Anmeldung MUSS Faktoren aus mindestens zwei unterschiedlichen Kategorien (Wissen, Besitz oder Inhärenz) berücksichtigen. Bei der Verwendung von Passwörtern MÜSSEN starke Passwörter technisch erzwungen werden.
- A.03.03** Dem Benutzer MUSS eine Möglichkeit gegeben werden, sich über erfolgreiche und gescheiterte Anmeldevorgänge zu seinem Benutzerkonto zu informieren.
- A.03.04** Die Webanwendung MUSS geeignete Maßnahmen gegen automatisierte und wiederholte Anmeldeversuche umsetzen (z. B. Ratenbegrenzung, temporäre Sperren).
- A.03.05** Authentifizierte Benutzer MÜSSEN die Möglichkeit haben, ihr Passwort zu ändern. Das Ändern und Rücksetzen von Passwörtern MUSS protokolliert werden. Das Passwort selbst DARF NICHT protokolliert werden.
- A.03.06** Werden Passwörter gespeichert, MÜSSEN diese mit einer den aktuellen Sicherheitsstandards entsprechenden *Hash*-Funktion und unter Verwendung geeigneter *Salts* gesichert werden.
- A.03.07** Funktionale Benutzerkonten DÜRFEN NUR für automatisierte technische Prozesse verwendet werden. Administrative Tätigkeiten durch Benutzende MÜSSEN unter personengebundenen Benutzerkonten erfolgen.

4.4 Session-Management

Dieser Abschnitt beschreibt IT-Sicherheitsanforderungen an das Session-Management der Webanwendung.

- A.04.01** *Session-IDs* MÜSSEN geeignet geschützt werden. Sie MÜSSEN zufällig und mit ausreichender Entropie erzeugt werden. Werden *Session-IDs* zwischen Client und Server übertragen, MUSS die Übertragung ausschließlich über eine gemäß TR-03116: „*Kryptographische Vorgaben für Projekte der Bundesregierung*“ [11] abgesicherte TLS-Verbindung erfolgen.
- A.04.02** Der Benutzer MUSS die Möglichkeit haben, eine bestehende Sitzung explizit zu beenden um die ausgestellte *Session-ID* zu invalidieren.
- A.04.03** Die Webanwendung MUSS nach einer angemessenen Zeit in der sie durch den Benutzer nicht aktiv verwendet wurde (*idle time*) die *Session-ID* invalidieren und eine erneute Authentisierung fordern.
- A.04.04** Die Webanwendung MUSS nach einer angemessenen Zeit in der sie aktiv verwendet wurde (*active time*) die *Session-ID* invalidieren und eine erneute Authentisierung zur Reaktivierung der Sessiversion fordern.
- A.04.05** Wird eine Anwendungssitzung ordnungsgemäß beendet, MUSS die Webanwendung das Hintergrundsystem (z. B. Backend-Server) darüber informieren, sodass *Session-ID* bzw. Authentisierungstoken sicher gelöscht werden. Dies gilt sowohl für das aktive Beenden durch den Benutzer (*log out*), als auch für das automatische Beenden durch die Anwendung. Bei erneuter Anmeldung des Benutzers MUSS eine neue *Session-ID* erzeugt werden.
- A.04.06** Beim Einsatz von Access Token MÜSSEN diese ausschließlich über eine integritätsgeschützte und verschlüsselte Transportverbindung übertragen werden, die den Anforderungen der TR-02102-2 [14] entsprechen.

- A.04.07** Beim Einsatz von *Self-contained-Token* (z. B. *Json-Web-Token*) DÜRFEN KEINE vertraulichen Informationen übermittelt werden. Die Token DÜRFEN NUR eine kurze Gültigkeit (max. 5 min) aufweisen und sie MÜSSEN signiert sein. Die Signatur MUSS vor dem Zugriff auf den Dienst oder die Ressource validiert werden.
- A.04.08** Kommen *Reference-Token* zum Einsatz bspw. im Hintergrundsystem, MÜSSEN sie stets beim ausstellenden Autorisierungsserver validiert werden.

4.5 Webanwendungen

- A.05.01** Zum Schutz vor *Clickjacking*, *Cross-Site-Scripting* und anderen Angriffen SOLLTEN geeignete *HTTP-Response-Header* gesetzt werden. Es SOLLTEN mindestens die folgenden HTTP-Header verwendet werden: *Content-Security-Policy*, *Strict-Transport-Security*, *Content-Type*, *X-Content-Type-Options* sowie *Cache-Control*. Die verwendeten HTTP-Response-Header SOLLTEN nach dem Prinzip der minimalen Freigabe konfiguriert werden. Es DÜRFEN NUR diejenigen Ausnahmen und Berechtigungen zugelassen werden, die für den bestimmungsgemäßen Betrieb der Webanwendung erforderlich sind.
- A.05.02** Cookies SOLLTEN grundsätzlich mit den Attributen *secure*, *SameSite* und *httponly* gesetzt werden.
- A.05.03** Die Webanwendung SOLLTE eine *same-origin-policy* umsetzen. Es KANN *cross-origin-resource-sharing* eingesetzt werden, um fachlich notwendige Dienste einzubinden.
- A.05.04** Die Integrität clientseitig eingebundener (Dritt-) Skripte MUSS sichergestellt werden. Skripte aus externen Quellen DÜRFEN NUR eingebunden werden, wenn ihre Authentizität und Integrität durch geeignete technische Maßnahmen gewährleistet werden.

4.6 Datenintegrität und -vertraulichkeit

Dieser Abschnitt befasst sich mit Vorgaben zu kryptografischen Operationen um Integrität und Vertraulichkeit der Anwendung zu gewährleisten. Dazu gehören unter anderem Schlüsselmanagement, die Speicherung von Passwörtern oder der Umgang mit Zertifikaten.

- A.06.01** Die Anwendung MUSS es ermöglichen, dass sämtliche Kommunikation zwischen Browser des Benutzers und Webserver integritätsgeschützt und transportverschlüsselt gemäß TR-02102-2 [14] stattfinden kann.
- A.06.02** Die Webanwendung MUSS auf bewährte Implementierungen zur Umsetzung kryptographischer Primitive und Protokolle zurückgreifen (vgl. [14]).
- A.06.03** Kryptographische Schlüssel DÜRFEN NICHT für mehr als einen Zweck eingesetzt werden.
- A.06.04** Die Webanwendung MUSS sicherstellen, dass ausschließlich gültige Zertifikate mit einer vertrauenswürdigen Zertifikatskette verwendet werden.
- A.06.05** Beim Einsatz von Verschlüsselung in der Webanwendung DÜRFEN KEINE fest einprogrammierten geheimen, bzw. privaten Schlüssel oder Passwörter eingesetzt werden.
- A.06.06** Die Webanwendung DARF KEINE vertraulichen Informationen in der URL kodiert übermitteln.
- A.06.07** Der Hersteller MUSS sicherstellen, dass in Formularen keine vertraulichen Formulardaten im Klartext angezeigt werden. Vertrauliche Formulardaten können bspw. folgende Informationen sein: Authentisierungsdaten, Sitzungs- und Authentisierungsinformationen, Kryptografische Schlüssel, Administrative Konfigurationsdaten oder Daten aus dem Wählerverzeichnis.
- A.06.08** Die Speicherung und Verarbeitung von sensiblen Daten SOLLTE im Hintergrundsystem erfolgen.

- A.06.09** Die Webanwendung SOLLTE sicherstellen, dass bei ihrer Beendigung alle sensiblen Daten und anwendungsspezifischen Anmeldeinformationen im Webbrowser des Benutzers nicht mehr zugänglich sind. Dies schließt insbesondere Cookies und Webstorage mit ein.
- A.06.10** Die Webanwendung MUSS geeignete Rollen und Funktionen bereitstellen, um die Überprüfung und Freigabe von Schnellmeldungen durch berechtigte Benutzer zu unterstützen.
- A.06.11** Die Webanwendung KANN die Durchführung von Plausibilitäts- und Konsistenzprüfungen unterstützen.
- A.06.12** Die Webanwendung MUSS sicherstellen, dass die zur Übermittlung vorgesehene Schnellmeldung vor dem Absenden vollständig angezeigt und durch die benutzende Person bestätigt werden kann. Zwischen Bestätigung und Übertragung MUSS die Integrität der Daten gewährleistet sein.

4.7 Eingabevalidierung

Die Anforderungen beziehen sich auf mögliche Eingaben und Ausgaben innerhalb der Webanwendung.

- A.07.01** Sämtliche an die Webanwendung übergebenen Daten MÜSSEN als potenziell gefährlich behandelt werden. Alle Eingabedaten MÜSSEN vor der Weiterverarbeitung geprüft und validiert werden. Die Überprüfung SOLLTE auf dem Server erfolgen.
- A.07.02** Ungültige oder nicht den Regeln entsprechende Eingaben MÜSSEN zurückgewiesen werden. Eine automatische Korrektur oder Veränderung von Eingaben SOLLTE vermieden werden. Ist eine Verarbeitung oder Bereinigung von Eingaben erforderlich, MUSS diese sicher und nachvollziehbar erfolgen.
- A.07.03** Falls Daten an ein *Datenbankmanagementsystem* (DBMS) weitergeleitet werden, MÜSSEN *stored procedures* bzw. *prepared SQL statements* eingesetzt werden. Falls dies aus technischen Gründen nicht möglich ist, MÜSSEN die *SQL queries* separat abgesichert werden.
- A.07.04** Die Anzahl der Sonderzeichen in einem Eingabefeld SOLLTE auf ein erforderliches Maß beschränkt werden. Es MUSS weiterhin sichergestellt werden, dass keine Sonderzeichen vorkommen, die in der folgenden Verarbeitungslogik zu unerwarteten Änderungen des Programmablaufs führen können. Werden diese zwingend benötigt, MUSS ein entsprechendes Encoding verwendet werden um sie im Kontext der Ausführungsumgebung unschädlich zu machen.
- A.07.05** Daten MÜSSEN vor ihrer Ausgabe entsprechend dem jeweiligen Ausgabekontext kodiert werden. Die Kodierung MUSS insbesondere bei HTML-, HTML-Attribut-, JavaScript-, CSS- und URL-Ausgaben erfolgen, sofern die Daten in diesen Kontexten verarbeitet werden. Eine Ausgabekodierung DARF NICHT durch das Entfernen oder Verändern potenziell gefährlicher Eingaben ersetzt werden. Die Ausgabekodierung MUSS insbesondere verhindern, dass bereitgestellte Inhalte als ausführbarer Code oder Skript interpretiert werden können.
- A.07.06** Feldlängen in Formularfeldern MÜSSEN auf eine geeignete Länge beschränkt sein.

4.8 Dateischnittstellen

Betrachtet werden an dieser Stelle nur Dateischnittstellen, die den Benutzer bei der Ergebnisübermittlung der Schnellmeldung unterstützen. Diese können dazu dienen, Formularfelder bei der manuellen Eingabe vorauszufüllen, um den Aufwand oder Übertragungsfehler zu minimieren.

- A.08.01** Falls die Webanwendung eine Upload-Funktion für Dateien anbietet, MUSS der Funktionsumfang so weit wie möglich eingeschränkt werden. Insbesondere MÜSSEN die erlaubte Dateigröße, erlaubte Dateitypen und erlaubte Speicherorte auf Serverseite festgelegt werden. Es MÜSSEN Zugriffs- und Ausführungsrechte restriktiv gesetzt werden.
- A.08.02** Hochgeladene Dateien MÜSSEN in einem vom Webserverdienst getrennten Bereich gespeichert werden, welcher zugriffsgeschützt ist und eine Ausführung von Dateien unterbindet.

- A.08.03** Der Dateiname von hochgeladenen Dateien SOLLTE durch die Webanwendung vor Speicherung geändert werden. Es MUSS sichergestellt sein, dass Kollisionen von Dateinamen nicht möglich sind. Der Dateiname DARF KEINE semantische Bedeutung bei der Datenhaltung tragen.
- A.08.04** Die Upload-Dateien MÜSSEN einem menschenlesbaren, semantischen Austauschformat, wie bspw. XML oder JSON, folgen. Der erlaubte Zeichensatz SOLLTE auf ein Minimum beschränkt werden.
- A.08.05** Die Upload-Datei MUSS vor der weiteren Verarbeitung auf erlaubten Zeichensatz, Schadcode und Schema hin überprüft werden. Schlägt eine dieser Prüfungen fehl, MUSS die weitere Verarbeitung unterbunden werden. Der Parser DARF ungültige oder nicht wohlgeformte Dateien NICHT automatisch korrigieren oder interpretieren.
- A.08.06** Jedes Datum aus der Upload-Datei MUSS entsprechend Abschnitt 4.7 separat überprüft werden.

4.9 Protokollierung

Protokollierung ist ein wichtiger Bestandteil zur Detektion von Sicherheitsvorfällen. Im Folgenden werden daher Anforderungen formuliert, die eine Detektion von Sicherheitsvorfällen ermöglichen sollen.

- A.09.01** Die Systemzeit aller protokollierenden IT-Systeme und Anwendungen MUSS mit einer vertrauenswürdigen und gegen Manipulation geschützten Zeitquelle synchronisiert werden. Es MUSS sichergestellt sein, dass Datums- und Zeitformat in Protokolldateien einheitlich und nachvollziehbar erfasst werden.
- A.09.02** Die Webanwendung MUSS alle sicherheitsrelevanten Ereignisse und Fehlermeldungen protokollieren. Falls eine veranlasste Aktion einen Fehler verursacht, MUSS die Webanwendung diese Aktion abbrechen. Die Webanwendung MUSS im Fehlerfall den Zugriff auf eine angeforderte Ressource oder Funktion verweigern. Interne Fehlerinformationen, insb. *Stacktraces*, *Exception*-Meldungen oder Informationen zur internen Systemarchitektur, DÜRFEN Benutzern NICHT angezeigt werden. Stattdessen MUSS eine allgemeine Fehlermeldung ausgegeben werden. Sicherheitskritische Ereignisse, wiederholt fehlgeschlagene Authentisierungsversuche, Manipulationsversuche oder kritische Systemfehler, MÜSSEN eine zeitnahe Alarmierung (Alert) der zuständigen Verantwortlichen (z. B. Administratoren) oder eines Monitoringsystems auslösen.
- A.09.03** Protokollierungsdaten SOLLTEN in einem einheitlichen Format gespeichert werden.
- A.09.04** Die Protokollierung der Ereignisse MUSS eine nachvollziehbare und nachträgliche Auswertung der Protokolldaten ermöglichen. Es SOLLTE eine Schnittstelle zum automatischen Auslesen der Protokolldaten implementiert sein.
- A.09.05** Es MUSS sichergestellt sein, dass die ausführenden Administrierenden selbst keine Berechtigung haben, die aufgezeichneten Protokollierungsdaten zu verändern oder zu löschen.
- A.09.06** Jede administrative Handlung, sowohl technischer als auch fachlicher Art, MUSS eindeutig auf eine Person zurückführbar sein und protokolliert werden.
- A.09.07** Werden im Rahmen der Wahlunterstützungssoftware personenbezogene Daten verarbeitet, MÜSSEN die Grundsätze der Datenminimierung und Zweckbindung berücksichtigt werden. Personenbezogene Daten DÜRFEN NUR erhoben, verarbeitet und gespeichert werden, soweit dies für den bestimmungsgemäßen Betrieb der Wahlunterstützungssoftware erforderlich ist.
- A.09.08** Die Wahlunterstützungssoftware MUSS sicherstellen, dass jede Schnellmeldung über ihre gesamte Verarbeitung hinweg nachvollziehbar ist. Hierzu MÜSSEN Erfassung, Verarbeitung, Übermittlung und Speicherung der Schnellmeldung manipulationsgeschützt protokolliert werden.
- A.09.09** Protokolldaten MÜSSEN gegen unbefugte Veränderung und Löschung geschützt werden. Die Integrität der Protokolldaten MUSS durch geeignete technische Maßnahmen sichergestellt werden.

5 Glossar

Nachfolgende Tabelle 4 enthält einige fachliche Begriffe, die in der vorliegenden Technischen Richtlinie verwendet werden.

Tabelle 4: Erläuterungen zu verwendeten Begriffen

Begriff	Beschreibung
Authentifizierung	Vorgang, bei dem die im Rahmen der Authentisierung vorgelegten Authentisierungsmerkmale überprüft werden, um die behauptete Identität zu bestätigen.
Authentisierung	Vorgang, bei dem eine Person, ein IT-System oder eine Softwarekomponente ihre behauptete Identität durch Vorlage geeigneter Authentisierungsmerkmale nachweist.
Benutzer	Natürliche Person, die mit der Wahlunterstützungssoftware oder ihren Komponenten interagiert und die ihr zugewiesenen Funktionen entsprechend ihrer Rolle nutzt.
Dateischnittstelle	Betrachtet werden an dieser Stelle nur Dateischnittstellen, die zur Ergebnisübermittlung der Schnellmeldung dienen. Verwendet werden könne sie bspw. um Formularfelder vorauszufüllen, den manuellen Aufwand zu minimieren oder Übertragungsfehler zu vermeiden.
Hintergrundsystem	Serverseitiges IT-System oder serverseitige Systemkomponente, die Funktionen oder Daten für die Wahlunterstützungssoftware bereitstellt oder verarbeitet und über definierte Schnittstellen angebunden ist.
Multi-Faktor-Authentisierung	Authentisierungsverfahren, bei dem die Identität einer Person anhand von mindestens zwei voneinander unabhängigen Authentisierungsfaktoren überprüft wird.
Schnittstelle	Technisch definierter Übergabepunkt für den Austausch von Daten zwischen der Wahlunterstützungssoftware und anderen IT-Systemen oder Softwarekomponenten. Schnittstellen können beispielsweise über Programmierschnittstellen (APIs), Netzwerkprotokolle oder Dateischnittstellen realisiert werden.
Wahlen	Verfahren zur Ermittlung des Wahlergebnisses durch die Stimmabgabe der Wahlberechtigten, die Auszählung der Stimmen sowie die Feststellung und Bekanntgabe des Wahlergebnisses nach den jeweils geltenden wahlrechtlichen Vorschriften.
Wähler	Person, die eine Wahlhandlung oder Teile davon ausführt.
Wählerverzeichnis	Verzeichnis aller Personen, die zur Teilnahme an der parlamentarischen Wahl berechtigt sind.
Wahlunterstützungssoftware	Informationstechnische Systeme oder Softwarekomponenten, die im Rahmen von Wahlen insbesondere zur Erfassung, Verarbeitung, Übermittlung, Aggregation, Auswertung oder Darstellung von Wahldaten eingesetzt werden.

6 Abkürzungsverzeichnis

Tabelle 5: Abkürzungsverzeichnis

Abkürzung	Begriff
API	Application Programming Interface
BMDS	Bundesministerium für Digitales und Staatsmodernisierung
BMI	Bundesministerium des Innern
BWL	Bundeswahlleitung
BWG	Bundeswahlgesetz
BWO	Bundeswahlordnung
CI/CD	Continuous Integration und Continuous Delivery, Continuous Deployment
CORS	Cross-Origin Ressource Sharing
DBMS	Datenbankmanagementsystem
DoS	Denial of Service
EDV	Elektronische Datenverarbeitung
EuWG	Europawahlgesetz
EuWO	Europawahlordnung
GG	Grundgesetz
IAM	Rollenmanagement, Identity and Access Management
IT	Informationstechnik
LWL	Landeswahlleitung
M2M	Machine-to-Machine
OWASP	Open Worldwide Application Security Project
SBOM	Software Bill of Materials
SLSA	Supply Chain Levels for Software Artifacts
TLS	Transport Layer Security
UI	User Interface
VPN	Virtual Private Network
VM	Virtual Mashine
WUS	Wahlunterstützungssoftware

Literaturverzeichnis

- [1] Bundesministerium der Justiz und für Verbraucherschutz, „Grundgesetz für die Bundesrepublik Deutschland,“ 22. 03. 2025. [Online]. Available: <https://www.gesetze-im-internet.de/gg/BJNR000010949.html>. [Zugriff am 01. 12. 2025].
- [2] Bundesministerin der Justiz und für Verbraucherschutz, „Bundeswahlordnung,“ 12. 09. 2024. [Online]. Available: https://www.gesetze-im-internet.de/bwo_1985/BJNR017690985.html. [Zugriff am 30. 06. 2026].
- [3] Bundesverfassungsgericht, „Urteil vom 3. März 2009,“ 03. 03. 2009. [Online]. Available: [https://www.bundesverfassungsgericht.de/SharedDocs/Entscheidungen/DE/2009/03/cs20090303_2bvc000307](https://www.bundesverfassungsgericht.de/SharedDocs/Entscheidungen/DE/2009/03/cs20090303_2bvc000307.html). [Zugriff am 01. 09. 2025].
- [4] Bundesministerium der Justiz und für Verbraucherschutz, „Bundeswahlgesetz,“ 03. 07. 2026. [Online]. Available: <https://www.gesetze-im-internet.de/bwahlg/BJNR003830956.html>. [Zugriff am 22. 06. 2026].
- [5] Bundesministerium der Justiz und für Verbraucherschutz, „Gesetze im Internet,“ 08 03 1994. [Online]. Available: <https://www.gesetze-im-internet.de/euwg/EuWG.pdf>. [Zugriff am 01 08 2026].
- [6] Bundesministerium der Justiz und für Verbraucherschutz, „Europawahlordnung,“ [Online]. Available: https://www.gesetze-im-internet.de/euwo_1988/. [Zugriff am 22. 06. 2026].
- [7] Bundesamt für Sicherheit in der Informationssicherheit, „IT-Grundschutz-Kompendium,“ 1 2 2023. [Online]. Available: https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschutz/IT-Grundschutz-Kompendium/it-grundschutz-kompendium_node.html. [Zugriff am 22 6 2026].
- [8] RFC-Editor, „RFC 2119 - Key words for use in RFCs to Indicate Requirement Levels,“ 1997. [Online]. Available: <https://www.rfc-editor.org/info/rfc2119>. [Zugriff am 22. 04. 2026].
- [9] O. Foundation, „OWASP Top 10 – Web Application Security Risks,“ 2025. [Online]. Available: <https://owasp.org/www-project-top-ten/>. [Zugriff am 02. 06. 2026].
- [10] Bundesamt für Sicherheit in der Informationstechnik, „Technische Richtlinie BSI TR-03185,“ 06. 08. 2024. [Online]. Available: <https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR03185/BSI-TR-03185.html>. [Zugriff am 22. 06. 2026].
- [11] Bundesamt für Sicherheit in der Informationstechnik, „Technische Richtlinie BSI-TR-03116-4,“ 03. 07. 2025. [Online]. Available: <https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR03116/BSI-TR-03116-4.html>. [Zugriff am 30. 06. 2026].
- [12] Open Source Security Foundation, „SLSA,“ [Online]. Available: <https://slsa.dev/>. [Zugriff am 30. 06. 2026].
- [13] Bundesamt für Sicherheit in der Informationstechnik, „Technische Richtlinie BSI TR-03183 Cyber-Resilienz-Anforderung,“ BSI, 20. 08. 2025. [Online]. Available: https://www.bsi.bund.de/SharedDocs/Downloads/EN/BSI/Publications/TechGuidelines/TR03183/BSI-TR-03183-2_v2_1_0.pdf?__blob=publicationFile&v=5. [Zugriff am 22. 06. 2026].

- [14] Bundesamt für Sicherheit in der Informationstechnik, „Technische Richtlinie BSI TR-02102-2,“ 21. 01. 2025. [Online]. Available: https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/Technische-Richtlinien/TR-nach-Thema-sortiert/tr02102/tr02102_node.html. [Zugriff am 30. 06. 2026].